UNIVERSIDAD NACIONAL DE CONCEPCIÓN
FACULTAD DE CIENCIAS ECONÓMICAS Y ADMINISTRATIVAS
Ingeniería en Informática Empresarial

Manual de Seguridad

FCEA Datasys
Controles del sistema y procedimientos de protección y recuperación

Trabajo Práctico Final de Ingeniería de Software I

Docentes
Prof. Lic. María Del Rosario Zorrilla A., Mg.
Prof. Ing. Juan Benito Torres Báez, Mg.

Integrantes
Alan Gabriel Cabrera Villalba
Ivan Ramon Duarte Villar
Fabrizio Ruben Larrosa Miranda
Thiago Mathias Torres Montania
Alan Amin Bogarín Godoy
Edgar Ibañez Meza

Concepción Paraguay
Octubre de 2026
Edición actualizada al 28 de octubre de 2026

Índice de contenido

Introducción 1
Desarrollo del manual 1
Responsabilidades y activos protegidos 1
Normas ISO de referencia 2
Controles de acceso físico 2
Protección y ubicación de los equipos 3
Antivirus y protección frente a archivos maliciosos 3
Actualización y comprobación de ClamAV 4
Seguridad para el acceso al sistema 5
Contraseñas y nivel de seguridad 6
Recuperación y correo seguro 6
Cifrado y protección criptográfica 7
Autorización y administración de privilegios 8
Auditoría de seguridad y de base de datos 9
Procedimiento de revisión 10
Copias de respaldo 10
Preparación y ubicación de las copias 10
Copia manual desde la aplicación o la terminal 11
Copias automáticas 12
Respaldo de adjuntos software y configuración 13
Restauración mediante el asistente actual 13
Validaciones y resultado de la restauración 13
Volver a la base anterior 14
Recuperación administrada en otro destino 14
Integridad de la información 15
Instalación y operación segura 15
Alertas que emite el sistema 16
Preguntas advertencias y estados visibles 16
Errores de autenticación y privilegios 17
Errores de validación integridad y archivos 18
Errores de informes copias y servicios 20
Respuesta a incidentes 21
Acceso o cuenta comprometida 21
Malware o pérdida de integridad 21
Fallo de auditoría o de continuidad 21
Verificaciones periódicas y límites pendientes 21
Conclusión 22
Fuentes de consulta 22

Introducción

Este manual establece cómo proteger la información y operar FCEA Datasys al 28 de octubre de 2026. Está dirigido al Administrador autorizado, TIC, Investigación y Biblioteca. Reúne los controles implementados y los procedimientos que la institución debe aplicar sobre personas, equipos, red, copias y respuesta a incidentes.

El catálogo guarda trabajos previamente aprobados; no realiza evaluación académica. El alcance comprende metadatos, cuentas, permisos, sesiones, adjuntos, auditoría, configuración y respaldos. Las medidas físicas y organizativas se presentan como requisitos de operación: revisar el código no acredita que ya estén instaladas en un servidor institucional. Tampoco se declara certificación ISO ni cumplimiento automático de la composición de contraseñas solicitada.

Se revisó el commit 97b4daa y el contrato maestro, dando prioridad a su ampliación de permisos del 26 de octubre. Las capturas usan exclusivamente datos de la demostración. No se ejecutó una restauración ni se alteraron registros bibliográficos para redactar estos manuales. Los ensayos históricos del repositorio no se presentan como una nueva validación de producción.

Desarrollo del manual

Responsabilidades y activos protegidos

Tabla 1 Responsabilidades de seguridad

Responsable	Obligación
Dirección de Investigación	Definir criterios de acceso y catalogación; aprobar responsables, retención y prioridades de continuidad.
Biblioteca y Digitador	Verificar procedencia, metadatos y obligación de conservar copia; reportar duplicados y archivos sospechosos.
Administrador autorizado	Crear y mantener cuentas, permisos y parámetros; revisar reportes, auditoría y resultados de copias según su permiso.
TIC	Proteger servidor y red; mantener SO, TLS, PostgreSQL, ClamAV y SMTP; custodiar secretos, tareas, adjuntos y recuperación.
Titular de cuenta	Usar una cuenta individual, proteger la clave, cerrar sesión e informar actividad no reconocida.
Personal visitante o proveedor	Acceder físicamente solo con autorización, registro y acompañamiento del responsable.

Los responsables concretos y sus suplentes deben designarse institucionalmente. El rol Administrador de la aplicación no concede por sí mismo acceso al sistema operativo, al cuarto técnico ni a PostgreSQL. La cuenta técnica que ejecuta servicios es distinta de una cuenta de usuario web.

Tabla 2 Activos amenazas y controles

Activo	Amenaza	Control principal
Metadatos y relaciones	Alteración, duplicación o pérdida	Validación, normalización, restricciones y transacciones.
Cuentas y sesiones	Suplantación o abuso	Hash Argon2id, bloqueo, sesión revocable y permisos efectivos.
Adjuntos	Malware, exposición o modificación	ClamAV, validadores, almacenamiento privado y SHA256.
Auditoría	Manipulación o falta de trazabilidad	Evento obligatorio, trigger de inmutabilidad y permisos SQL.
Copias y secretos	Pérdida, robo o divulgación	Destino privado, cuenta restringida, verificación y recuperación ensayada.
Infraestructura	Falla eléctrica, agua, incendio o acceso indebido	Control físico, UPS, ubicación protegida, mantenimiento y supervisión.

Normas ISO de referencia

ISO/IEC 27001:2022 define requisitos de un sistema de gestión de seguridad de la información. Se toma como referencia para identificar riesgos, asignar responsables, tratar incidentes y mejorar los controles. ISO/IEC 27002:2022 aporta orientación para seleccionar y operar controles de acceso, protección de activos, criptografía y respuesta. Sus fichas oficiales se incluyen en Fuentes de consulta.

Aplicar estas referencias al proyecto exige inventariar activos, evaluar amenazas y sus efectos, decidir controles, conservar evidencia y revisar su eficacia. La documentación del software no equivale a una auditoría de certificación. No se dispone de evidencia de una certificación ISO de FCEA Datasys ni de la infraestructura institucional.

Controles de acceso físico

El servidor y los equipos centrales deben permanecer en un recinto o gabinete con acceso controlado. Solo TIC y las personas designadas para operación, mantenimiento o recuperación deben tener acceso habitual. Investigación y Biblioteca acceden a la aplicación con sus cuentas; su función operativa no exige entrar al recinto del servidor.

1. Mantener una lista autorizada de personas y un responsable de llaves, tarjetas o control equivalente. Revisarla cuando cambien funciones o personal.
2. Registrar ingreso, salida, motivo y acompañante de visitantes y proveedores. Retirar o devolver las credenciales al concluir.
3. Cerrar puerta y gabinete; impedir acceso público a consolas, puertos, medios extraíbles, botones de reinicio y discos.
4. Separar el acceso físico de la autorización web y evitar cuentas compartidas de mantenimiento.
5. Documentar intervenciones, cambios de hardware y salida de medios de almacenamiento. Cuando un equipo se retire, proteger sus datos antes de traslado o disposición.

La institución debe verificar y registrar qué mecanismos existen en su instalación. Este manual no supone la presencia de biometría, cámaras o un centro de datos específico. La evidencia mínima es la autorización de responsables y el registro de accesos e intervenciones.

Protección y ubicación de los equipos

Tabla 3 Protección de infraestructura

Equipo o zona	Condiciones que deben verificarse
Servidor y almacenamiento	Gabinete estable y cerrado, ventilación y temperatura según fabricante; lejos de líquidos, tuberías, ventanas expuestas, polvo y vibraciones. No apoyar equipos en el piso susceptible de inundación.
Comunicaciones y cableado	Switches, routers, cortafuegos y centros de cableado en gabinetes protegidos; cables identificados, sujetos y separados de fuentes de interferencia. Restringir cambios de conexiones.
Energía y UPS	Puesta a tierra y protección eléctrica revisadas por personal competente; UPS dimensionada y probada para permitir cierre ordenado. Evitar sobrecarga y conexiones improvisadas.
Ambiente y seguridad electrónica	Prevenir fuego, agua, explosivos, vandalismo, polvo e interferencia electromagnética. Mantener detección y medios de respuesta apropiados y acceso libre para emergencia.
Aire acondicionado y telefonía	Mantener climatización, drenajes y equipos asociados sin riesgo de goteo o sobrecalentamiento. Proteger centrales y enlaces que sostengan la operación.
Estaciones de trabajo	Ubicación bajo supervisión; bloqueo del SO al ausentarse; no dejar contraseñas visibles. Impedir lectura incidental de información administrativa.
Dispositivos móviles y medios de copia	Inventario y custodia; protección de acceso y cifrado administrado cuando almacenen datos sensibles. No usar medios desconocidos ni dejar la única copia junto al servidor.

TIC debe mantener inventario, responsable, ubicación y plan de mantenimiento de equipos. Revisar capacidad de disco y ventilación antes de ampliar la colección. Las pruebas de energía o recuperación deben planificarse para no interrumpir el servicio sin coordinación. Las medidas de ubicación y UPS son controles de infraestructura y no funciones automáticas de la aplicación.

Antivirus y protección frente a archivos maliciosos

ClamAV es el motor antimalware integrado para analizar los bytes de cada adjunto antes de habilitarlo. FreshClam descarga y actualiza sus bases de firmas, según la documentación oficial. TIC debe disponer además de protección antimalware vigente en los equipos que administren o consulten documentos, con actualizaciones del sistema operativo y análisis acordes a su plataforma. ClamAV en el servidor no sustituye la protección completa de las estaciones.

La aplicación valida formato y contenido, calcula el hash y ejecuta clamscan sin shell ni argumentos proporcionados por el archivo. PDF es el formato inicial; TXT puede habilitarse porque cuenta con validador. Un resultado detectado, cifrado o no analizable no se habilita. A diferencia de una herramienta

de desinfección general, el producto rechaza el documento: no promete reparar automáticamente su contenido ni desinfectar memoria, correo o discos completos.

Tabla 4 Etapas de control del adjunto

Etapa	Condición para continuar
Autorización y recepción	Sesión vigente, permiso efectivo, multipart y tamaño acotado.
Nombre y formato	Nombre sanitizado; extensión habilitada y contenido compatible. El MIME declarado por el navegador no basta.
PDF	Firma de PDF y terminador EOF admitidos; no constituye una validación estructural exhaustiva del estándar.
TXT habilitado	Contenido UTF-8 compatible con el validador; no basta cambiar la extensión.
Identidad	SHA256 calculado por el servidor y unicidad persistente.
Antimalware	Motor disponible, firmas suficientemente recientes y análisis completo con resultado limpio.
Persistencia	Archivo privado y registro CLEAN con verificación, motor y fecha.
Lectura posterior	Tipo de archivo regular, sin enlaces simbólicos, tamaño y hash coincidentes; autorización y auditoría previas a entrega.

Actualización y comprobación de ClamAV

1. Instalar el ejecutable oficial y comprobar la carpeta de firmas configurada por TIC.
2. Actualizar con FreshClam. En Windows, desde la raíz, el proyecto incluye el comando de abajo; en Linux operar freshclam con su configuración autorizada.
3. Comprobar el código de salida y el registro de actualización. Verificar que el servicio usa la misma carpeta de firmas actualizada.
4. Programar y supervisar las actualizaciones a nivel del sistema operativo. La aplicación no instala una tarea de actualización de firmas por sí misma.
5. Probar una carga de documento inocuo en un entorno de prueba y confirmar su resultado. Las pruebas de detección se realizan únicamente en un entorno controlado.

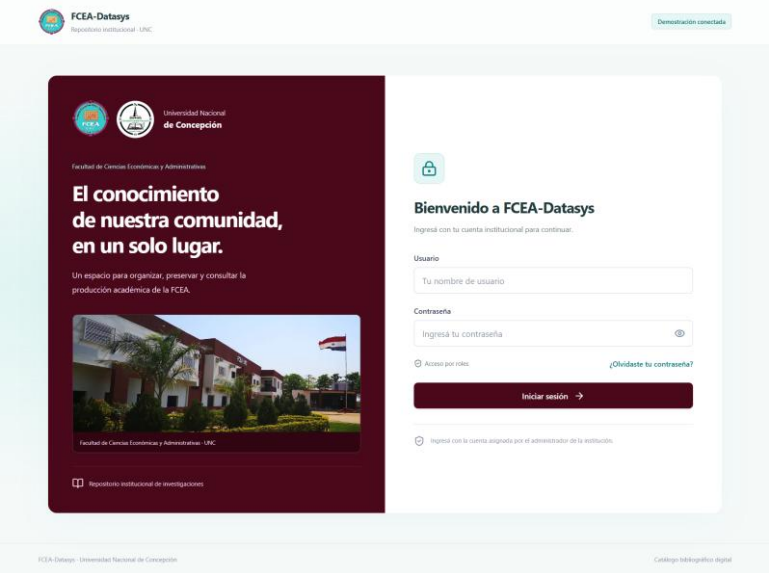
```
powershell -NoProfile -File server/scripts/update-clamav.ps1
```

La configuración admite CLAMAV_TIMEOUT_MS de 1000 a 300000 ms, CLAMAV_MAX_SIGNATURE_AGE_DAYS de 1 a 30 días y ATTACHMENT_CONCURRENCY de 1 a 8; los valores iniciales del servidor son 120000 ms, siete días y dos análisis simultáneos. Son parámetros técnicos del entorno, no controles de la ventana Parámetros generales. TIC debe mantener las firmas al día, no esperar al umbral máximo para actualizarlas.

Si falta el ejecutable, vencen las firmas, se agota el tiempo o el análisis es incompleto, la carga se bloquea. Si se detecta un archivo malicioso, mantenerlo fuera de circulación, registrar incidente y solicitar una copia segura. La eliminación física excepcional debe identificar exactamente el archivo, conservar la trazabilidad y estar auditada. No existe una limpieza periódica ni un reanálisis automático de toda la colección instalado por el producto.

Seguridad para el acceso al sistema

Figura 1 Ingreso autenticado al sistema



El acceso requiere usuario y contraseña de una cuenta activa. No hay registro público libre. Las identidades CI, correo y usuario se validan y se protegen con unicidad en la base. El Administrador o gestor autorizado debe comprobar la identidad, asignar el mínimo acceso necesario y entregar credenciales mediante un canal privado. Las cuentas demo y sus claves conocidas no se utilizan en producción.

Tabla 5 Accesos iniciales por rol

Acción	Administrador	Digitador	Público
Consultar catálogo y buscar	Sí	Sí	Sí
Perfil y contraseña propia	Sí	Sí	Sí
Crear y editar publicaciones	Sí	Sí	No
Cargar y descargar adjuntos	Sí	Sí	No
Gestionar autores y tutores	Sí	Sí	No
Inactivar publicaciones y consultar historia	Sí	No	No
Otros catálogos y parámetros	Sí	No	No
Administrar usuarios	Sí	No	No
Reportes y auditoría	Sí	No	No
Gestionar permisos y copias	Sí con permiso	No delegable	No delegable

Estos son los accesos iniciales. La ampliación autorizada del 26 de octubre permite configurar permisos por rol y excepciones por cuenta. Heredar aplica la regla del rol; Permitir o Denegar la sustituye para esa cuenta. Los permisos efectivos del servidor determinan cada acción. Administrar permisos y ejecutar copias se reservan siempre al rol Administrador con su permiso correspondiente. Debe conservarse al menos un Administrador activo con permissions.manage.

Contraseñas y nivel de seguridad

Política requerida por la consigna. Usar al menos ocho caracteres, con un mínimo de dos letras mayúsculas, dos minúsculas, dos números y dos caracteres especiales. Una contraseña más larga y exclusiva para el sistema puede cumplir estos mínimos. No utilizar nombres, documentos personales ni claves de demostración en producción.

Control automático actual. El código admite de 8 a 128 caracteres y exige al menos una letra ASCII y un número; no obliga a reunir las cuatro cantidades anteriores ni comprueba una lista de contraseñas comunes. La composición más estricta debe adoptarse como política institucional y queda pendiente su validación automática en frontend y backend. Este manual documenta la diferencia; no afirma que el producto ya la impida ni modifica el software.

El cambio personal requiere clave actual y una nueva diferente; preserva la sesión vigente sin extender sus plazos y revoca las demás sesiones y recuperaciones pendientes. La asignación administrativa a otra cuenta revoca las sesiones de esa cuenta. Nunca se muestra la contraseña existente. Una persona que desconoce su clave utiliza recuperación; esta no habilita una cuenta inactiva.

Tabla 6 Parámetros de autenticación y sesión

Control	Comportamiento actual
Login fallido	Tres errores consecutivos bloquean por cinco minutos a la cuenta. El mensaje público permanece genérico: Usuario o contraseña incorrectos.
Sesión	Máximo absoluto de siete días y diez minutos de inactividad. Las lecturas y renovaciones automáticas no cuentan como actividad humana.
Access token	JWT firmado HS256, vigencia de 900 segundos, emisor, audiencia, usuario y sesión verificados. Se guarda en memoria del cliente.
Refresh	Token aleatorio en cookie HttpOnly y SameSite Strict; Secure en producción; hash persistido y rotación con detección de reutilización.
Navegador	Contexto compartido y coordinación entre pestañas. Una identidad activa debe recuperarse o cerrarse antes de iniciar otra en el mismo contexto.
Confirmación protegida	Contraseña actual del operador en modificaciones y bajas. Tres confirmaciones fallidas consecutivas revocan la sesión compartida.
Recuperación	Enlace de quince minutos y un uso; hasta tres solicitudes por correo y por IP durante una hora; respuesta general que no confirma existencia ni entrega.

El vencimiento de sesión se registra al detectarse por una operación y se calcula con el límite efectivo correspondiente. Una petición tardía no debe ampliar el tiempo de sesión auditado. Al ausentarse bloquear también el sistema operativo y al terminar usar Cerrar sesión, sin confiar exclusivamente en cerrar la pestaña.

Recuperación y correo seguro

1. Solicitar recuperación desde el ingreso con el correo de la cuenta.
2. Leer la respuesta general y revisar el correo sin compartir su enlace.
3. Abrir el enlace antes de quince minutos, definir y repetir una nueva clave.

4. Si está vencido o consumido, solicitar otro; si no llega, TIC revisa SMTP y disponibilidad.
5. Después del cambio ingresar con la nueva clave y comprobar que no exista actividad ajena.

El token se genera con 32 bytes aleatorios y solo se guarda su SHA256. SMTP valida certificados y exige TLS 1.2 como mínimo: TLS implícito en el puerto 465 o STARTTLS cuando corresponde. La cola de entrega está en memoria y es limitada; un cierre abrupto puede perder una entrega pendiente. La respuesta uniforme de recepción no garantiza que haya salido un correo. No copiar tokens, cookies ni enlaces de recuperación a logs, capturas o tickets.

Cifrado y protección criptográfica

Las contraseñas se almacenan como hash Argon2id con sal aleatoria, memoria de 19456 KiB, dos iteraciones y paralelismo uno. Es una derivación no reversible: no existe descifrado para recuperar la clave original. Al autenticar se verifica el hash. TIC debe calibrar el costo en el servidor de destino sin debilitarlo unilateralmente.

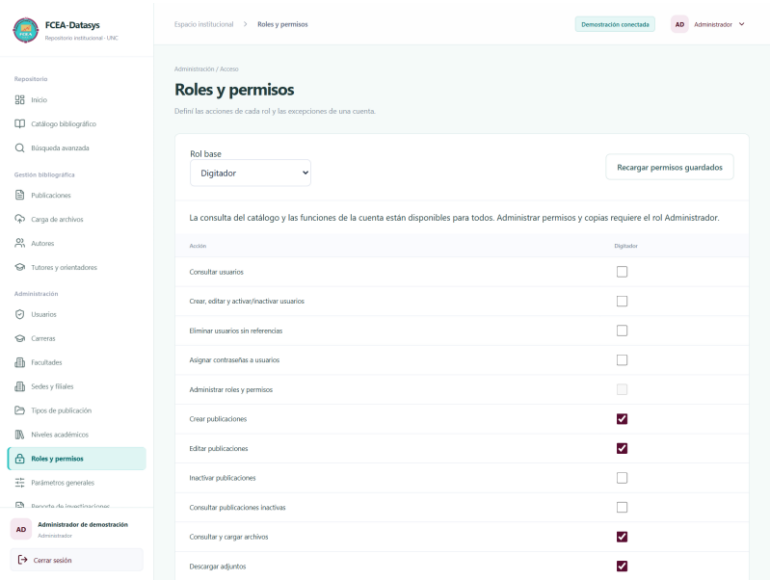
Tabla 7 Uso de mecanismos criptográficos

Dato o canal	Mecanismo y límite
Contraseñas	Argon2id con sal. No se guardan en texto claro ni se cifran de forma reversible.
Transporte web	HTTPS en producción, certificado válido y TLS 1.2 mínimo. La API privada se mantiene en loopback.
JWT	Firma HS256 para integridad y autenticidad del token; su contenido no se considera cifrado.
Refresh y recuperación	SHA256 persistido en lugar del token crudo. Los tokens son aleatorios y deben mantenerse privados.
Publicaciones y adjuntos	SHA256 para duplicados y verificación de integridad; el hash no oculta el contenido.
Confirmación de contraseña	Base64 representa UTF-8 en el encabezado. Base64 no es cifrado y requiere HTTPS.
Dump y archivos en disco	El producto no agrega cifrado propio de los .dump ni de los adjuntos en reposo. TIC debe proteger volúmenes y medios con su política de cifrado y custodia.

Los certificados, secretos JWT y autorización de Drive se guardan en ubicaciones privadas. No se incluyen en Git, en el cliente web ni en una entrega académica. La protección criptográfica requiere custodiar las claves de recuperación por separado; cifrar una copia sin conservar su clave puede impedir restaurarla.

Autorización y administración de privilegios

Figura 2 Permisos por rol y excepciones por cuenta



Autorización es el permiso concedido a una cuenta para actuar sobre un recurso. El servidor obtiene identidad, rol y sesión de credenciales verificadas y PostgreSQL. No acepta como prueba un rol, actor o bitácora enviado por el navegador. Los permisos efectivos combinan el rol con excepciones individuales; abrir una dirección o mantener una ventana antigua no concede acceso.

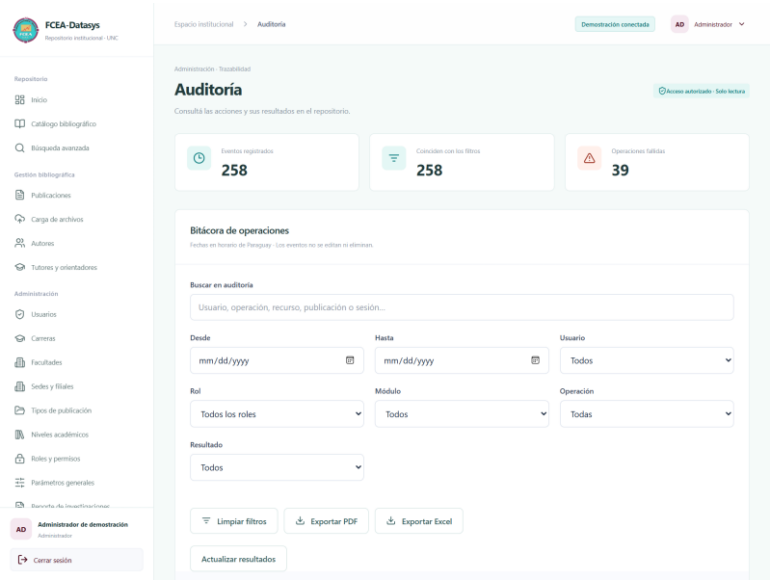
1. Solicitar y registrar la necesidad de acceso con el área responsable.
2. Revisar la política del rol y las excepciones actuales de la cuenta.
3. Con Administrador y permissions.manage seleccionar las acciones necesarias; evitar permisos ajenos a la tarea.
4. Guardar con versión vigente y contraseña actual, comprobar el resultado y revisar el evento PERMISOS_MODIFICADOS.
5. Al cambiar funciones o retirar personal, revisar permisos y sesiones. Si las reglas de referencias impiden inactivar, coordinar una restricción de permisos y un procedimiento técnico autorizado que conserve la historia.

El servidor protege al último Administrador activo y al último Administrador activo con permissions.manage. Un gestor de usuarios sin ese permiso no cambia roles ni modifica cuentas con privilegios superiores, incluso por la ruta de asignación de contraseña. La cuenta propia no cambia su rol o estado mediante mantenimiento. La consulta, exportación y eliminación son facultades distintas.

Las operaciones PATCH y DELETE protegidas requieren contraseña actual y, cuando corresponde, If-Match sobre un ETag. Se revalidan actor, sesión, permisos, referencias y versión dentro de la transacción. Si otro operador cambió datos, la aplicación obliga a revisarlos en vez de sobrescribir. La autorización se vuelve a comprobar antes de confirmar escrituras o entregar información sensible.

Auditoría de seguridad y de base de datos

Figura 3 Consulta de la bitácora inmutable



Una auditoría de seguridad verifica que los controles existen, se aplican y responden al objetivo de proteger el catálogo. La bitácora registra accesos, fallos, logout y tiempos de sesión; cargas y modificaciones bibliográficas; inactivaciones, archivos y descargas; usuarios, roles, catálogos, parámetros y permisos; copias y rechazos por validación o seguridad.

Tabla 8 Contenido del evento auditado

Dato	Utilidad
ID y fecha de evento	Identificar el registro y ordenar temporalmente la actividad. El servidor conserva fecha UTC y la interfaz muestra fecha institucional.
Usuario rol y sesión	Reconocer actor y rol del momento cuando están identificados; una tarea técnica puede no tener usuario web.
Operación recurso y publicación	Localizar la acción y el identificador afectado.
IP y User-Agent	Aportar contexto de conexión. No prueban por sí solos la identidad física de una persona.
Éxito o Fallido y detalle	Distinguir cambio confirmado, rechazo y motivo.
Valores anteriores y nuevos	Comparar la modificación mediante una proyección segura, normalmente JSON.

La base refuerza la inmutabilidad con triggers y privilegios: el runtime no tiene UPDATE ni DELETE de logs. No hay rutas HTTP de edición o eliminación de auditoría. La operación protegida y su evento se confirman en la misma transacción. Si la escritura del log falla, se cancela la operación. Los rechazos se auditan después del rollback para no perder su evidencia. Las entregas HTTP o SMTP no forman una transacción distribuida con PostgreSQL.

Procedimiento de revisión

1. Acceder con audit.read. Por defecto corresponde al Administrador y puede delegarse expresamente según el contrato vigente.
2. Delimitar fechas, actor, rol, módulo, operación y resultado; conservar el criterio utilizado.
3. Abrir detalle y comparar antes y después cuando exista. Revisar login fallido repetido, cambios de permisos, rechazos de archivos, inactivaciones y fallos de respaldo.
4. Correlacionar con logs del sistema operativo, PostgreSQL y mantenimiento cuando el incidente lo exija. Mantener hora sincronizada.
5. Exportar con audit.export y custodiar el informe con acceso limitado; no editar el log para corregir un dato de negocio.
6. Registrar hallazgos, responsable de revisión, corrección y comprobación posterior en la bitácora operativa.

La base usa cuentas separadas para propietario de migraciones, runtime y lector de copias. TIC debe comprobar periódicamente los grants y mecanismos de inmutabilidad. El control limita al usuario de aplicación y no elimina el poder de un superusuario o del administrador del sistema operativo; sus credenciales y accesos requieren controles administrativos independientes. No registrar contraseñas, hashes de contraseñas, tokens, Authorization, cookies ni rutas privadas en eventos o informes.

Copias de respaldo

Una copia permite recuperar un estado anterior después de pérdida o daño. El motor actual genera un archivo PostgreSQL custom .dump, comprueba cabecera e índice y conserva una copia local; luego sube a Drive y verifica su identidad, carpeta, nombre, tamaño y MD5. El SHA256 se registra en auditoría. El respaldo cubre la base completa, incluidos metadatos y logs; no incorpora por sí mismo los bytes de los adjuntos ni todos los recursos del servidor.

Preparación y ubicación de las copias

Tabla 9 Ubicaciones y recursos de recuperación

Recurso	Ubicación o configuración
Copia PostgreSQL local	Carpeta privada definida en BACKUP_DIRECTORY. Ejemplo de destino operativo, no ruta universal: C:/FCEA/private/backups.
Copia remota	Carpeta privada Drive identificada por DRIVE_FOLDER_ID y el nombre configurado; acceso con la cuenta Google autorizada.
Configuración de copias	Archivo privado .local/backups/production.env o la ruta indicada por BACKUP_CONFIG_FILE. Demo utiliza un archivo separado.
Adjuntos	Directorio ATTACHMENT_DIRECTORY y su respaldo independiente compatible con el estado de la base.
Configuración software y secretos	Versión compatible del código, lockfiles, migraciones, archivos privados, certificados, roles y permisos del servidor; custodia separada.
Registros de restauración	Bitácora local .local/backups/restores/PERFIL/ID/events.jsonl y eventos en la base cuando corresponde.

1. Preparar pg_dump y pg_restore compatibles, destino privado y una cuenta de lectura exclusiva.

2. Comprobar que DATABASE_URL, MIGRATION_DATABASE_URL y BACKUP_DATABASE_URL apunten al mismo host, puerto y base del perfil, con sus usuarios técnicos correspondientes.

3. Autorizar el JSON OAuth de escritorio, archivo de token y carpeta Drive mediante la guía del proyecto.

4. En Windows restringir ACL a la cuenta de servicio y responsables; en Linux usar directorios 0700 y secretos 0600 según la guía. No servir esas rutas por HTTP.

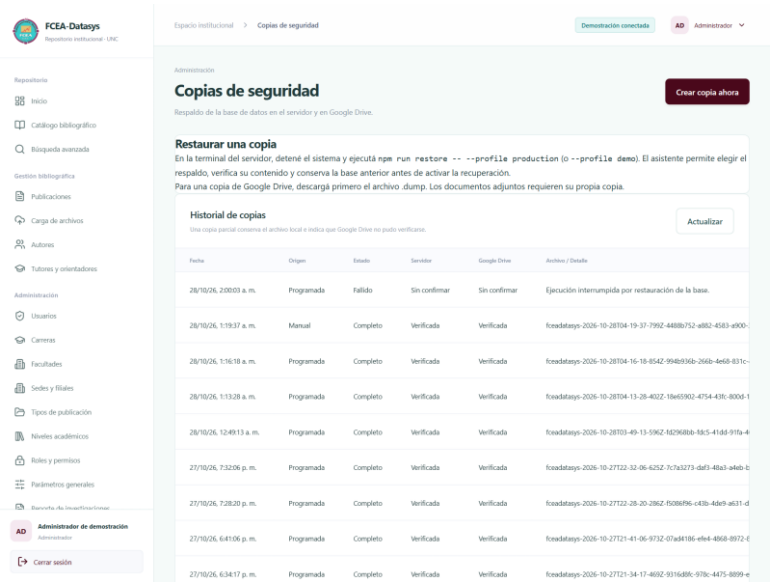
5. Ejecutar una primera copia y comprobar su resultado final antes de depender de una programación.

```
npm run configure -- --profile production
npm run backup:authorize -- --profile production
```

La autorización de Drive solicita drive.file, utiliza PKCE y state y un callback temporal solo en 127.0.0.1. El JSON del cliente y el archivo que guarda el refresh token son privados y distintos. La cuenta del servicio debe poder actualizar atómicamente el token. La audiencia externa de Google en modo Prueba puede emitir tokens que caducan a los siete días; el perfil local production no cambia ese estado de Google. Ante revocación, revisar y reautorizar con el responsable.

Copia manual desde la aplicación o la terminal

Figura 4 Control del resultado de las copias manuales y programadas



1. En Copias de seguridad, con Administrador y backups.manage, elegir Crear copia ahora una sola vez; como alternativa TIC ejecuta npm run backup del perfil.

2. Esperar el resultado del historial. La aceptación HTTP 202 o Copia iniciada solo informa que el trabajo fue recibido.

3. Comprobar nombre, fecha, origen, estado local y Drive; abrir auditoría para conservar el SHA256 del intento.

4. Ante estado parcial conservar el local y corregir la nube; ante fallo revisar la causa antes de repetir.

5. Comprobar el índice y programar un ensayo de restauración; una copia existente no demuestra que todo el sistema pueda recuperarse.

```
npm run backup -- --profile production
```

```
pg_restore --list "RUTA_DE_LA_COPIA.dump"
Get-FileHash -LiteralPath "RUTA_DE_LA_COPIA.dump" -Algorithm SHA256
```

Tabla 10 Estados y respuesta del operador

Estado	Condición	Respuesta
EN_CURSO	Motor procesando o resultado aún sin confirmar.	Esperar y actualizar; no asumir éxito.
COMPLETO	Dump local e identidad de archivo Drive verificados.	Custodiar y ensayar recuperación integral.
PARCIAL	Local válido y envío o verificación remota fallida.	Conservar local, revisar conexión o autorización y crear otro intento.
FALLIDO	No se confirmó copia local o se detectó ejecución interrumpida.	Revisar logs, espacio, herramientas y conexión; no usar parciales como copia confirmada.

Un bloqueo PostgreSQL impide solapar copias manuales y programadas. Si falla la auditoría inicial no se ejecuta pg_dump. Si falla la confirmación final, el motor intenta retirar solo los archivos de ese intento, incluido el ID de Drive reservado y auditado. Si la nube no permite compensar, TIC debe revisar ese ID. Disco, PostgreSQL y Drive no participan en una transacción distribuida.

Copias automáticas

La programación usa el Programador de tareas de Windows o el crontab de la cuenta en Linux. Puede funcionar sin web ni API, siempre que PostgreSQL y los recursos necesarios estén disponibles. En demo, el lanzador detiene el clúster que inició al cerrarse; una tarea no lo encontrará si está apagado.

```
npm run backup:schedule -- --profile production --time 02:00 --dry-run
npm run backup:schedule -- --profile production --time 02:00
npm run backup:schedule -- --profile production --time 23:30
npm run backup:schedule -- --profile production --disable
```

1. Revisar el dry-run, la ruta del proyecto, perfil, cuenta y hora. HH:MM es hora local del servidor; comprobar su zona y usar America/Asuncion si es el horario institucional acordado.
2. Registrar la tarea con una cuenta autorizada sobre configuración, firmas, herramientas y carpetas privadas. Windows puede requerir credenciales del sistema operativo y privilegios administrativos.
3. En Windows comprobar desencadenador, acción, directorio de trabajo, identidad de ejecución y último resultado. En Linux revisar crontab -l, servicio cron y .local/backups/PERFIL.log.
4. Esperar una ejecución por horario, comprobar archivo y estado final local/remoto y conservar evidencia de fecha y resultado. Ejecutarla a mano no acredita el disparador automático.
5. Si se cambia horario, actualizar la tarea del mismo perfil; no crear duplicados ni modificar tareas ajenas.

Windows usa StartWhenAvailable para recuperar una ejecución perdida según la tarea configurada. Cron no recupera por sí mismo horarios perdidos durante un apagado. La política de retención, cantidad de generaciones, almacenamiento alternativo y revisión de fallos debe aprobarse institucionalmente: el producto no borra automáticamente copias ni impone un RPO o RTO.

Respaldo de adjuntos software y configuración

TIC debe copiar ATTACHMENT_DIRECTORY con un estado compatible del dump, además de versión de aplicación, migraciones, configuración, certificados y definición de roles. Coordinar una ventana de mantenimiento o captura consistente para evitar que la base refiera un archivo aún no conservado. No trasladar adjuntos a client/public para facilitar la copia. Conservar una generación fuera del mismo equipo o zona de falla conforme a la política institucional.

Definir y registrar RPO, pérdida de datos máxima aceptable, y RTO, tiempo objetivo de recuperación. Medir el RTO mediante un ensayo completo; el intervalo diario es una elección de programación y no una garantía de continuidad. Proteger copias con acceso limitado, cifrado de medios según política y custodia de claves por separado. Las copias contienen datos personales y hashes de credenciales.

Restauración mediante el asistente actual

Este procedimiento corresponde a TIC y requiere una instalación existente cuya base actual, configuración y roles sigan accesibles. El asistente restaura primero en una base nueva, verifica compatibilidad y adjuntos y conserva la anterior. No hay endpoint ni botón web de restauración. Para pérdida total o servidor diferente se utiliza el procedimiento administrado posterior.

```
npm run stop:production
npm run restore -- --profile production --list
npm run restore -- --profile production
npm run start:production
```

1. Identificar la fecha del respaldo y el punto de recuperación aceptado. Conservar una copia adicional del estado actual y registrar el mantenimiento.
2. Detener el sistema y esperar su cierre. El asistente rechaza un lanzador activo o conexiones abiertas; no fuerza desconexiones.
3. Elegir la copia local por número. Si procede de Drive, descargarla previamente con la cuenta autorizada a una carpeta privada y pasar --file con su ruta.
4. Verificar perfil, host, puerto, base destino, archivo y SHA256 mostrado. Comparar con la auditoría de origen. Si no puede localizarse el hash original, proporcionar --sha256 con el valor obtenido de una fuente confiable.
5. Escribir exactamente RESTAURAR seguido del nombre real de la base solo después de revisar el resumen. No existe una opción para omitir esta confirmación interactiva.
6. Esperar restauración y validaciones. No iniciar la web en paralelo ni borrar bases temporales durante el proceso.
7. Reiniciar con start:production solo si se confirmó activación. Ingresar de nuevo, revisar cuentas, permisos, catálogos, publicaciones, adjuntos y auditoría y registrar el resultado.

```
npm run restore -- --profile production --file "C:/FCEA/recuperacion/copia.dump"
```

Para demo sustituir production por demo. Las rutas y nombres de ejemplo deben reemplazarse por los valores de la instalación; no son una instrucción para restaurar una base determinada durante la lectura del manual.

Validaciones y resultado de la restauración

El asistente reserva el bloqueo del lanzador, prepara una copia privada de entrada y comprueba cabecera, índice y SHA256. Restaura con pg_restore --single-transaction en una base nueva usando el propietario. Compara migraciones y checksums con la versión instalada: no migra silenciosamente respaldos de otra

versión. Verifica un Administrador activo con permissions.manage y comprueba tamaño y hash del contenido CLEAN. Si faltan documentos, recuperar primero sus archivos compatibles.

Después restablece grants del runtime y lector, prueba las conexiones, revoca las sesiones y refresh recuperados y retira enlaces antiguos de recuperación. Marca como fallidos los intentos de copia que aparezcan en curso dentro del dump. Registra la validación y activa mediante dos renombrados en una transacción. La base recuperada toma el nombre configurado y la anterior se conserva con sufijo _previous_IDENTIFICADOR y nuevas conexiones deshabilitadas. En esta vía no es necesario cambiar URLs, credenciales ni programación.

Si falla la activación se revierten los renombrados. Una recuperación fallida puede conservar una base _restore_IDENTIFICADOR y el input.dump para diagnóstico; no hay borrado automático de bases. Se registran RESTAURACION_INICIADA, RESTAURACION_VALIDADA y RESTAURACION_FALLIDA cuando corresponde, identificando al operador del sistema operativo sin inventar una sesión web. Si la auditoría obligatoria falla, no se activa la recuperación. El registro local events.jsonl complementa los eventos SQL y no contiene contraseñas.

Volver a la base anterior

Si la comprobación posterior requiere retroceder, detener la aplicación y usar una conexión técnica autorizada a la base de mantenimiento postgres. TIC debe utilizar los nombres exactos indicados por el asistente, sin conexiones activas. En una misma transacción, deshabilitar conexiones a la base actual, renombrarla a un nombre libre, renombrar la base _previous_ al nombre original y habilitar sus conexiones. Conservar ambas bases, comprobar adjuntos y registrar el resultado antes de reiniciar. La reversión requiere planificación y acceso técnico; no debe ejecutarse copiando nombres de ejemplo.

Recuperación administrada en otro destino

1. Ante pérdida total, recuperar configuración privada y roles globales mediante su custodia independiente; un dump de una sola base no crea los roles de PostgreSQL.
2. Preparar un servidor y una base nueva vacía con un propietario autorizado y versión compatible. No utilizar el lector de copias como cuenta de restauración.
3. Verificar procedencia e integridad del dump y revisar su índice. Restaurar en una sola transacción con el propietario.
4. Aplicar grants del runtime y preparar la lectura de copias. Recuperar adjuntos y comprobarlos frente a la base.
5. Revocar sesiones y enlaces recuperados mediante el procedimiento técnico previsto y documentado; validar administrador, permisos, relaciones, auditoría y acceso real.
6. Actualizar coherentemente DATABASE_URL, MIGRATION_DATABASE_URL y BACKUP_DATABASE_URL solo si el destino cambia, con su usuario correspondiente. Comprobar TLS, SMTP, Drive y programación.
7. Conservar el estado anterior hasta aprobar el ensayo y registrar tiempos, pérdidas y resultados.

```
pg_restore --list "RUTA_DE_LA_COPIA.dump"
pg_restore --host=127.0.0.1 --port=5432 --username=PROPIETARIO \
  --dbname=BASE_NUEVA --no-owner --no-acl --single-transaction "RUTA_DE_LA_COPIA.dump"
```

La barra inversa del ejemplo anterior representa continuidad de línea en un shell compatible. En PowerShell escribir el comando pg_restore en una sola línea y reemplazar PROPIETARIO, BASE_NUEVA y la ruta por los valores autorizados. Proporcionar contraseñas mediante mecanismos privados de PostgreSQL; no escribirlas en argumentos ni capturas. Para los grants utilizar

server/scripts/runtime-grants.sql con app_role igual al rol real del runtime. Esta vía administrada requiere controles adicionales y no sustituye las comprobaciones del asistente.

Integridad de la información

La integridad asegura que un dato no cambie sin autorización durante procesamiento, transporte, almacenamiento o recuperación, y permite detectar alteraciones. FCEA Datasys combina restricciones de base, transacciones, autorización, versiones y hashes. Estos controles se complementan: un hash correcto no concede permiso y una sesión válida no permite romper una referencia.

Tabla 11 Controles de integridad

Etapa	Mecanismo implementado
Registro bibliográfico	Normalización Unicode y texto comparable; unicidad individual de título, resumen y abstract; duplicados rechazados de forma explícita.
Participantes y catálogos	Claves foráneas y relaciones N a M; autores sin repetir y con orden; tutores sin repetir; referencias activas y del tipo correcto.
Concurrencia	Bloqueos, ETag e If-Match, revalidación transaccional y restricciones únicas contra carreras.
Archivos	Hash SHA256 y reserva persistente; bytes analizados antes de habilitar; lectura privada con tamaño, tipo y hash comprobados.
Transporte	HTTPS y validación de certificado en producción; origen permitido y cookies protegidas.
Auditoría	Escritura inseparable del cambio, valores seguros anteriores y nuevos e inmutabilidad SQL.
Inactivación	Conservación de registros históricos; un dato inactivo sigue reservando valores de duplicados.
Restauración	Hash de origen, índice del dump, transacción, migraciones compatibles, referencias y adjuntos verificados antes de activación.

Un administrador técnico podría alterar tanto archivos como hashes si sus credenciales se comprometen. Por eso se separan cuentas, se restringe acceso físico, se conservan copias independientes y se revisan eventos. Las URLs externas solo se validan como HTTP o HTTPS y se almacenan; la API no visita ni analiza su contenido y no garantiza la integridad futura de otro sitio.

Instalación y operación segura

1. Preparar SO mantenido, Node.js 24.11 o superior de la rama 24, PostgreSQL 18 y ClamAV con firmas vigentes.
2. Crear almacenamiento privado, dominio y certificados TLS PEM válidos; exponer únicamente el acceso web y mantenimiento autorizados.
3. Ejecutar npm run configure -- --profile production y revisar cada destino antes de aplicar. Conservar es la opción inicial si ya existe una base.

4. Separar propietario de migración, runtime limitado y lector de copias; restringir ACL y retirar credenciales administrativas permanentes del entorno de ejecución.

5. Configurar SMTP y comprobar recuperación con una cuenta autorizada. Preparar Drive y una primera copia verificada.

6. Registrar con el gestor institucional el servicio de aplicación para arranque permanente; el asistente no lo instala automáticamente.

7. Comprobar salud, acceso desde la red autorizada, descarga privada, tareas de copia y actualización de firmas. Conservar evidencia sin secretos.

Producción exige HTTPS, cookies Secure y URL de recuperación HTTPS. Si falla TLS no debe degradarse a HTTP. La API usa loopback y solo proxies locales explícitamente confiables. Los orígenes se autorizan de manera exacta. El asistente no instala programas del SO, DNS, firewall ni certificados públicos por sí mismo.

Eliminar y recrear una base desde instalación es diferente de restaurar. La recreación elimina su contenido y exige copia previa verificada, destino revisado, confirmación ELIMINAR con el nombre real y ausencia de conexiones. No debe utilizarse como solución rutinaria a un error de acceso o catálogo. La operación documental de estos manuales no solicita ni ejecuta una recreación.

Alertas que emite el sistema

La interfaz combina errores, advertencias, preguntas de confirmación, estados informativos y mensajes de éxito. El texto de detalle puede variar según el campo y el recurso. El siguiente inventario agrupa los códigos presentes en el servidor al momento de la revisión; son identificadores existentes de Problem Details, no nuevos códigos creados para este manual. La respuesta incluye status, code, title, detail, timestamp, path e invalid_params cuando corresponde.

Preguntas advertencias y estados visibles

Tabla 12 Alertas operativas sin un código exclusivo

Tipo y aviso	Cuándo aparece y respuesta
Confirmación de registro	Al dar de alta datos protegidos. Revisar el resumen y Confirmar o Cancelar.
Confirmar operación	Al editar o dar de baja. Solicita la contraseña actual del operador; Cancelar abandona.
Inactivar investigación	Antes de retirar una publicación del conjunto activo. Conserva historia; continuar pide identidad.
Activar o inactivar usuario o catálogo	Al cambiar estado. Leer el nombre y sus efectos antes de continuar.
Eliminar definitivamente	Al solicitar baja física de cuenta o catálogo. Advierte que no puede deshacerse y que exige ausencia de referencias.
Los datos cambiaron o revisar versión	Conflicto concurrente. Consultar, comparar y aceptar la revisión antes de reintentar.
Campo obligatorio o formato inválido	Validación del navegador o servidor. Corregir el campo marcado, contador, fecha, selección o confirmación.

Tipo y aviso	Cuándo aparece y respuesta
Contraseñas no coinciden	Nueva contraseña y confirmación diferentes. Reescribir ambos campos.
No hay resultados o catálogo vacío	Consulta sin coincidencias o directorio sin registros. Ampliar filtros o crear referencias con permiso.
No se generará un archivo vacío	Reporte sin datos. No es un fallo de generación; cambiar filtros si corresponde.
Cargando consultando verificando o iniciando	Operación pendiente. Esperar; los botones pueden deshabilitarse para impedir envíos repetidos.
Investigación guardada o cambios guardados	Escritura confirmada por el servidor; comprobar el registro y su código.
Contraseña actualizada	Cambio confirmado; las otras sesiones o recuperaciones se revocan según el recorrido.
Solicitud de recuperación recibida	Respuesta general; no confirma cuenta existente ni entrega de correo.
Copia iniciada	Se aceptó el intento; comprobar su estado final.
Copia En curso Completo Parcial o Fallido	Resultado del trabajo de copia. Aplicar la respuesta de la tabla de estados.
Copias todavía no configuradas	No se encontró configuración de respaldo. TIC prepara carpeta y autorización.
Archivo seleccionado admitido o cargado	Se comunica selección o carga según etapa; solo un resultado limpio permite asociarlo.
Acceso restringido	La cuenta no puede abrir la ventana. Pedir revisión de permisos, sin intentar eludir el servidor.
RESTAURAR o ELIMINAR con nombre de base	Confirmación en terminal del encargado. Revisar destino y respaldo antes de aceptar; no pertenece a la web.

Errores de autenticación y privilegios

Tabla 13 Autenticación y autorización

Código existente	Cuándo aparece y qué hacer
INVALID_CREDENTIALS	Usuario o contraseña incorrectos; el mismo mensaje cubre el bloqueo temporal. Revisar y esperar cinco minutos tras tres fallos.
ACCOUNT_INACTIVE	Cuenta inactiva con clave verificada. Solicitar revisión administrativa.
UNAUTHENTICATED	Sesión ausente, vencida, revocada o cerrada por confirmaciones fallidas. Volver a ingresar y consultar datos.

Código existente	Cuándo aparece y qué hacer
FORBIDDEN	Permiso insuficiente. Solicitar autorización al responsable.
ORIGIN_FORBIDDEN	Origen HTTP no admitido. TIC revisa la URL y configuración; no desactivar el control.
SESSION_MISMATCH	Bearer y cookie pertenecen a sesiones distintas. Cerrar o recuperar de forma consistente la sesión del navegador.
BROWSER_SESSION_ACTIVE	Ya existe sesión activa en el contexto del navegador. Recuperarla o cerrarla antes de iniciar otra.
INVALID_CURRENT_PASSWORD	Contraseña actual incorrecta en cambio personal. Verificar escritura.
INVALID_CONFIRMATION_PASSWORD	Contraseña de confirmación incorrecta. Verificar la propia; tres fallos cierran la sesión.
CONFIRMATION_REQUIRED	Falta la contraseña de confirmación o no es válida su representación. Volver al diálogo.
CONFIRMATION_EXPIRED	La contraseña cambió durante el recorrido. Cancelar y confirmar con la vigente.
INVALID_RECOVERY_TOKEN	Enlace inválido, consumido o vencido. Solicitar uno nuevo.
PASSWORD_UNCHANGED	La nueva contraseña coincide con la actual. Elegir otra.
SELF_ADMIN_PASSWORD_CHANGE	Se intentó usar la ruta administrativa sobre la cuenta propia. Abrir cambio personal.
SELF_PRIVILEGE_CHANGE	Cambio prohibido de rol o estado propio. Utilizar el procedimiento de otro gestor autorizado.
PUBLIC_NAME_READONLY	Nombre de Público protegido. Conservarlo y revisar identidad con el responsable.
LAST_ADMIN_REQUIRED	La operación dejaría sin Administrador activo. Mantener al menos uno.
LAST_PERMISSION_ADMIN_REQUIRED	La operación dejaría sin Administrador activo con permissions.manage. Corregir la política.

Errores de validación integridad y archivos

Tabla 14 Datos y archivos

Código existente	Cuándo aparece y qué hacer
VALIDATION_ERROR	Campo, fecha, rango, formato o cuerpo inválido. Revisar invalid_params y corregir.
DUPLICATE_USER	CI, correo o usuario ya utilizado. Buscar la cuenta existente.

Código existente	Cuándo aparece y qué hacer
DUPLICATE_CATALOG	Nombre o identificador normalizado ya utilizado en el catálogo. Revisar el existente.
DUPLICATE_PUBLICATION	Título, resumen o abstract duplicado normalizado. No registrar otra copia.
DUPLICATE_ATTACHMENT	El hash del archivo ya existe o está reservado. No volver a cargarlo.
USER_IN_USE	Referencias protegidas impiden baja de cuenta. Conservar historia y revisar vínculos.
CATALOG_IN_USE	Publicaciones o referencias impiden estado o eliminación. Mantener el elemento y revisar dependencias.
INVALID_PUBLICATION_REFERENCE	Referencia inexistente, inactiva o de un catálogo incorrecto. Seleccionar una opción válida.
INVALID_ATTACHMENT	Archivo, identificador, contenido, extensión o tamaño incompatibles. Aportar un documento válido.
ATTACHMENT_NOT_READY	Adjunto sin verificación limpia o no disponible para vincular. Revisar su estado y propiedad.
ATTACHMENT_REJECTED	Contenido sospechoso o detección antimalware. No distribuir; avisar a TIC y obtener copia segura.
ANTIMALWARE_UNAVAILABLE	No se completó análisis por motor, firmas o tiempo. La carga no se habilita; TIC restablece el control.
ATTACHMENT_SERVICE_BUSY	Capacidad simultánea de análisis ocupada. Esperar y reintentar una vez.
ATTACHMENT_UNAVAILABLE	Archivo ausente, alterado o inaccesible en almacenamiento. No entregar; revisar integridad y copia.
NOT_FOUND	Recurso o ruta inexistente. Actualizar consulta y verificar identificador.
RESOURCE_VERSION_CONFLICT	Registro cambiado por otro operador. Obtener y comparar la versión actual.
USER_VERSION_CONFLICT	Versión de cuenta anterior a la vigente. Recargar y revisar.
PRECONDITION_FAILED	Publicación modificada o no coincide su versión. Revisar antes de reenviar.
PRECONDITION_REQUIRED	Falta If-Match u otra precondición documentada. Reabrir el registro y consultar versión.

Errores de informes copias y servicios

Tabla 15 Disponibilidad y exportaciones

Código existente	Cuándo aparece y qué hacer
REPORT_LIMIT_EXCEEDED	Reporte supera límites de registros, texto o bytes. Reducir filtros.
REPORT_VERSION_CONFLICT	La captura del informe cambió. Actualizar vista previa y revisar.
REPORT_SERVICE_BUSY	Generación de informes temporalmente ocupada. Esperar.
REPORT_GENERATION_FAILED	No se pudo generar un informe. Consultar de nuevo y comunicar a TIC si persiste.
AUDIT_EXPORT_LIMIT	Exportación de auditoría supera sus límites. Acotar período o criterios.
AUDIT_VERSION_CONFLICT	Eventos o filtros no coinciden con la captura exportable. Actualizar resultados.
AUDIT_EXPORT_BUSY	Exportación de auditoría ocupada. Esperar y volver a solicitar.
BACKUP_BUSY	Ya existe un respaldo en ejecución. Consultar el intento actual.
BACKUP_NOT_CONFIGURED	Configuración ausente o no válida. TIC revisa recursos privados y autorización.
AUDIT_UNAVAILABLE	No pudo escribirse la auditoría; la operación se cancela. Restablecer el registro antes de continuar.
RATE_LIMITED	Límite de solicitudes. Esperar; revisar automatizaciones que repiten operaciones.
INTERNAL_ERROR	Fallo interno sin detalle sensible expuesto. No asumir éxito; verificar y comunicar a TIC.
GATEWAY_ERROR	Acceso web rechazado o API no disponible: ruta o cuerpo inválido, Host incompatible, error interno o conexión. TIC revisa gateway y API.

También pueden aparecer errores de red del navegador, respuesta o descarga inesperada de la API, consulta cancelada y nombre de archivo recibido no válido. Cancelar una consulta o un diálogo no implica un cambio confirmado. No publicar cuerpos completos ni secretos para diagnosticar; registrar ventana, hora, identificador y mensaje. Los fallos de preparación y restauración se detallan en la terminal y events.jsonl sin inventar códigos HTTP nuevos.

Respuesta a incidentes

Acceso o cuenta comprometida

1. Anotar cuenta, fecha, ventana y actividad no reconocida sin copiar secretos. Avisar a TIC por el canal institucional.
2. Contener el acceso mediante cambio de contraseña y restricciones autorizadas; revisar revocación de sesiones y permisos.
3. Consultar logins, cambios de identidad, permisos y descargas; preservar eventos y logs del SO.
4. Corregir causa, comprobar acceso legítimo y registrar cierre. Si las referencias impiden inactivar, coordinar el tratamiento sin borrar historia.

Malware o pérdida de integridad

1. Interrumpir distribución y no abrir ni reenviar el archivo sospechoso.
2. Identificar publicación, archivo y hash. TIC aísla el contenido y preserva trazabilidad.
3. Verificar firmas, motor y estado del almacenamiento; analizar en un entorno controlado.
4. Recuperar una copia limpia o aplicar eliminación física excepcional auditada según el contrato. No eliminar indiscriminadamente registros o logs.
5. Comprobar documentos relacionados y registrar medidas y resultado.

Fallo de auditoría o de continuidad

1. Ante auditoría indisponible respetar la cancelación de operaciones protegidas; no desactivar el control para continuar.
2. TIC revisa conexión PostgreSQL, permisos, espacio y logs, preservando evidencia.
3. Ante copia parcial mantener el local y restablecer nube; ante fallo total generar y verificar una copia nueva.
4. Si se perdió información, elegir el punto recuperable y aplicar restauración administrada con adjuntos compatibles.
5. Registrar causa, afectación, tiempos, datos recuperados y acciones preventivas.

Verificaciones periódicas y límites pendientes

Tabla 16 Revisión y evidencia esperada

Momento	Verificación y evidencia
Cada respaldo	Estado final, nombre, ubicación, SHA256, disponibilidad local y remota.
Operación diaria recomendada	Servicios, espacio, actualización de firmas, errores de tareas y registros relevantes.
Alta baja o cambio de función	Identidad, rol, excepciones, cuenta activa y sesiones; autorización y evento.
Cambio de software o parámetros	Copia recuperable previa, migraciones, grants, compatibilidad y prueba de acceso.

Momento	Verificación y evidencia
Ensayo según política	Restauración completa, adjuntos, cuentas, permisos, auditoría, servicios, RPO y RTO medidos.
Revisión de infraestructura	Inventario, autorizados, gabinete, energía, UPS, ventilación y conservación de medios.
Incidente	Evidencia preservada, contención, causa, recuperación y comprobación de cierre.

Brechas y responsabilidades pendientes. La composición de contraseña exigida por la consigna no se valida automáticamente en la versión actual. La instalación física, el dimensionamiento, el cifrado de medios, la retención, RPO y RTO requieren decisiones y evidencia institucional. ClamAV no instala por sí mismo actualización de firmas ni reanálisis periódico. El motor de copias no incluye automáticamente adjuntos ni configuración. SMTP, OAuth de producción, certificados y tareas deben probarse en su entorno real. Estas condiciones no se dan por cumplidas por el solo hecho de existir el código o el manual.

Conclusión

La seguridad de FCEA Datasys depende de mantener juntos el acceso individual, los permisos efectivos, los controles de archivos, la auditoría y una recuperación comprobada. El software aporta barreras transaccionales y trazabilidad; TIC y las áreas responsables deben completar la protección física, la actualización, la custodia y las pruebas de continuidad. Antes de declarar cumplimiento institucional deben resolverse y verificarse las brechas explícitas, especialmente la validación de composición de contraseñas y el respaldo integral de adjuntos y configuración.

Fuentes de consulta

Fecha de consulta y revisión: 28 de octubre de 2026. Estado del repositorio: commit 97b4daa. Se contrastaron el contrato maestro, los formularios y esquemas vigentes y las guías operativas; una descripción histórica se descartó cuando contradijo el código o la ampliación de permisos.

1. Equipo FCEA Datasys. AGENTS.md. Contrato maestro del proyecto, incluida la ampliación de permisos del 26 de octubre de 2026.

2. Cabrera Villalba, A. G.; Duarte Villar, I. R.; Larrosa Miranda, F. R.; Torres Montania, T. M.; Bogarín Godoy, A. A.; e Ibañez Meza, E. (2026). TPF - 3er avance - Manual de usuario FCEA Datasys.docx. Antecedente aportado por el usuario; describe una demostración anterior.

3. Equipo FCEA Datasys. docs/entrega-final-2026-10-27/02 Manual de usuario.docx y 03 Manual de seguridad.docx. Antecedentes documentales de la versión conectada.

4. Equipo FCEA Datasys. README.md; docs/DEPLOYMENT.md; docs/INSTALLATION-PRODUCTION.md; docs/PERMISSIONS.md; docs/BACKUPS.md y docs/GOOGLE-DRIVE.md. Instalación, permisos y continuidad.

5. Equipo FCEA Datasys. server/docs/API.md, CATALOGS.md, PUBLICATIONS.md, PUBLICATION-MANAGEMENT.md, PUBLICATION-QUERIES.md, ATTACHMENTS.md y REPORTS.md. Contratos funcionales y mensajes.

6. Equipo FCEA Datasys. client/src/AuthPage.tsx, ApiApp.tsx, navigation.ts, ApiPublicationForm.tsx, ApiPublicationPages.tsx, ApiBibliographicPages.tsx, CatalogPage.tsx, UserPages.tsx,

PermissionsPage.tsx, SettingsPage.tsx, AttachmentPage.tsx, AuditPage.tsx y BackupsPage.tsx. Pantallas y operaciones.

7. Equipo FCEA Datasys. server/src/users/schemas.ts, catalogs/schemas.ts, publications/schemas.ts y security/crypto.ts. Tipos, límites y política de contraseñas.

8. Equipo FCEA Datasys. Capturas originales de la aplicación conectada al perfil demo, obtenidas el 28 de octubre de 2026 para estos manuales. Los datos mostrados son ficticios.

9. Equipo FCEA Datasys. server/src/security, attachments, auditing, backups y errors.ts; scripts/restore.mjs; scripts/backups/restore.mjs y schedule.mjs; server/prisma/migrations y server/scripts/runtime-grants.sql. Controles, transacciones y restauración.

10. ISO. (2022). ISO/IEC 27001:2022. Sistemas de gestión de seguridad de la información. Ficha oficial: https://www.iso.org/standard/27001

11. ISO. (2022). ISO/IEC 27002:2022. Controles de seguridad de la información. Ficha oficial: https://www.iso.org/standard/75652.html

12. ClamAV. Manual de uso, análisis y actualización de firmas. https://docs.clamav.net/manual/Usage y https://docs.clamav.net/manual/Usage/SignatureManagement.html

13. PostgreSQL Global Development Group. PostgreSQL 18. pg_dump y pg_restore. https://www.postgresql.org/docs/18/app-pgdump.html y https://www.postgresql.org/docs/18/app-pgrestore.html

14. Google. Drive API v3. Subidas y autorización de acceso a archivos. https://developers.google.com/workspace/drive/api/guides/manage-uploads y https://developers.google.com/identity/protocols/oauth2/native-app